

INTERNSHIP PROJECT REPORT

Web Application Security Assessment & Improvement

Week 1: Security Assessment Report

1. Application Setup

During Week 1, a Node.js-based User Management web application was downloaded from GitHub and configured as the target environment for cybersecurity testing. The following steps were carried out to establish a working test environment:

- Extracted the project files and navigated to the project directory
- Installed all required dependencies using `npm install`
- Launched the application using `node app.js`
- Accessed the running application at `http://localhost:3000`
- Explored key application pages including Signup, Login, and Dashboard

This setup provided a stable, locally hosted to perform security testing throughout the week.

2. Tools Used

Tool	Purpose
OWASP ZAP	Automated web application vulnerability scanning and passive/active attack simulation
Browser Developer Tools	Manual inspection of HTTP requests, responses, headers, and client-side behaviour
Manual Input Testing	Human-led input-based testing to identify validation weaknesses and logic flaws

3. Testing Methodology

The following tests were performed across key areas of the application. Each test used targeted payloads or techniques to determine the presence or absence of specific vulnerabilities.

Test Performed	Payload / Method	Result
XSS Testing	<code><script>alert('XSS')</script></code>	✓ Secure
SQL Injection	<code>admin' OR '1'='1</code>	✓ Secure
Input Validation	Invalid / malformed inputs	✓ Secure
Password Policy	Weak password attempts	✓ Secure
Brute Force Testing	Repeated failed login attempts	✗ Vulnerable

3.1 Test Details

XSS Testing: The payload `<script>alert('XSS')</script>` was submitted across all input fields. No script execution occurred, confirming the application is not vulnerable to basic XSS.

SQL Injection: The payload `admin' OR '1'='1` was used in the login form. Authentication failed, indicating the application is not vulnerable to basic SQL injection.

Input Validation: Invalid and malformed inputs were submitted across registration and login forms. All invalid inputs were correctly rejected, confirming proper validation is in place.

Password Policy: Weak password submissions were tested against the registration form. All were rejected, confirming that password strength rules are actively enforced.

Brute Force Testing: Multiple consecutive incorrect login attempts were submitted without any restriction or lockout being triggered. This confirms the application is **vulnerable to brute-force attacks**.

4. Vulnerabilities Identified

The following findings summarise the security status of each area tested during the assessment:

Finding	Status
Not vulnerable to basic XSS attacks	✓ Secure
SQL Injection attempts were unsuccessful	✓ Secure
Input validation is properly implemented	✓ Secure
Password policy is correctly enforced	✓ Secure
Vulnerable to brute-force attacks — unlimited login attempts	✗ Vulnerable

5. Secure Features

The following security controls were found to be correctly implemented as expected:

Verified Secure Controls

- ✓ Input validation — all forms reject malformed and invalid data
- ✓ Password policy — weak passwords are refused at registration
- ✓ XSS protection — script injection payloads are neutralised
- ✓ SQL injection protection — parameterised queries prevent injection

Conclusion

The Week 1 security assessment revealed that the User Management Web Application has a solid foundation of basic security controls, including input validation, password enforcement, and resistance to XSS and SQL injection attacks.

Assessment Summary

- 4 out of 5 tests passed — the application demonstrates good baseline security.
- 1 critical gap identified: no brute-force protection on the login endpoint.
- Security misconfigurations (missing headers, CORS) were also noted.
- Improvements are recommended before deploying to a production environment.
- This assessment identified both strengths and areas requiring further hardening.

This report concludes the Week 1 security assessment for the internship project.